

Data Retention and Disposal Policy

Atman · Operator: Eyob Tsegaye Yosef, Buffalo, New York, USA

Contact: eyobt646@gmail.com

Version 1.0 · Effective July 17, 2026 · Next review: July 17, 2027

1. Purpose

This policy defines how Atman retains, reviews, and permanently disposes of consumer data, including financial data obtained through the Plaid API. It exists to ensure data is kept only as long as necessary to deliver the service and is destroyed securely when no longer required.

2. Scope

This policy applies to all consumer data processed by Atman, including data stored in the Supabase-managed PostgreSQL database, data transmitted to service providers (Plaid, OpenAI), and any data present on the operator's development device. It applies to the sole operator and to any future employees or contractors.

3. Data Categories and Retention Periods

Data Category	Examples	Retention Period
Account and identity data	Email address, authentication record, user profile	Retained while the account is active. Deleted immediately upon user-initiated account deletion.
Plaid connection data	Plaid Item records, access tokens, institution identifiers	Retained while the bank connection is active. Deleted, and the Item revoked with Plaid, upon disconnection or account deletion.
Financial account data	Account names, masks, types, balances	Retained while the account is active. Deleted immediately upon account deletion.
Transaction data	Transaction descriptions, amounts, dates, categories	Retained while the account is active to provide historical spending analysis. Deleted immediately upon account deletion.
Derived product data	Detected subscriptions, budgets, goals, balance snapshots, generated insights	Retained while the account is active. Deleted immediately upon account deletion.
Assistant conversation data	User messages and assistant responses in the in-app coach	Retained while the account is active. Deleted immediately upon account deletion.
Operational logs	Edge Function invocation and error logs	Retained by the hosting platform for a rolling window of no more than 90 days, then automatically purged. Logs do not contain access tokens or bank credentials.

4. Consumer-Initiated Deletion

Consumers may permanently delete their account and all associated data at any time, without contacting support, from within the application at **Settings** → **Delete Account & All Data**.

This action is executed by a dedicated server-side function that, in a single operation:

- Revokes each associated Plaid Item through the Plaid **/item/remove** endpoint, terminating the institution connection and preventing any further data retrieval;
- Deletes all stored Plaid Item records and access tokens;
- Deletes all financial accounts, transactions, balance snapshots, detected subscriptions, budgets, goals, and generated insights belonging to the user;
- Deletes all assistant conversation messages belonging to the user;
- Deletes the user profile record;
- Deletes the authentication record, permanently removing the account.

Deletion is enforced at the database level through ON DELETE CASCADE foreign key constraints referencing the authentication record, ensuring no orphaned consumer data remains. Deletion is immediate and irreversible. No backup copy of deleted consumer data is retained beyond the platform's standard encrypted database backup window, after which it is permanently overwritten.

5. Deletion Upon Account Disconnection

If a consumer disconnects an individual financial institution without deleting their entire account, the corresponding Plaid Item is revoked through the Plaid API and the associated accounts, transactions, and access tokens for that institution are deleted.

6. Disposal Method

Consumer data is stored exclusively in a managed PostgreSQL database with encryption at rest. Disposal is performed by permanent database record deletion. No consumer financial data is written to local files, exported to third-party storage, or persisted on consumer devices; the mobile application holds data only in volatile memory during a session. Development devices use full-disk encryption, and any device retired from use is securely erased before disposal or reuse.

7. Third-Party Processors

- **Plaid** — connection revocation is requested through **/item/remove** at deletion; Plaid applies its own retention obligations to data it holds.
- **Supabase** — hosts the encrypted database and authentication records; deletion requests are executed directly against these systems.
- **OpenAI** — receives only aggregated, summarized financial context necessary to generate a response. Bank credentials and access tokens are never transmitted. No consumer data is used to train third-party models.

8. Legal and Regulatory Compliance

This policy is designed to comply with applicable United States data privacy laws, including state consumer privacy statutes that grant rights of access and deletion. Where a legal obligation requires retention of specific records beyond the periods above, that obligation takes precedence for the minimum period

required, after which the data is disposed of under this policy.

9. Enforcement and Review

The operator is responsible for enforcing this policy. Because deletion is implemented programmatically within the application and enforced by database-level cascade constraints rather than by manual process, enforcement is automatic and consistent for every consumer request. This policy is reviewed at least annually and upon any material change to data collection, storage architecture, or third-party processors.

10. Contact

Eyob Tsegaye Yosef — eyobt646@gmail.com